

# PROPOSAL TEKNIS

---

---

## IPB Food Hub & UMKM

*Platform Marketplace Digital UMKM Kampus Berbasis Web*

---

**Mata Kuliah:** Keamanan Informasi (KOM1315)

**Program:** Ilmu Komputer, FMIPA IPB University

**Semester:** Genap 2025/2026

## Daftar Isi

|                                                      |    |
|------------------------------------------------------|----|
| Daftar Isi.....                                      | 2  |
| 1. Deskripsi Sistem.....                             | 3  |
| 1.1. Latar Belakang .....                            | 3  |
| 1.2. Gambaran Sistem .....                           | 3  |
| 1.3. Tujuan Sistem.....                              | 3  |
| 1.4. Arsitektur Sistem.....                          | 4  |
| 1.5. Fitur Inti .....                                | 5  |
| 1.5.1. Manajemen UMKM dan Menu .....                 | 5  |
| 1.5.2. Alur Pemesanan dan Pembayaran .....           | 5  |
| 1.5.3. Sistem Rating dan Ulasan .....                | 5  |
| 1.5.4. Promo dan Diskon.....                         | 5  |
| 1.5.5. Dashboard Keamanan (Security Dashboard) ..... | 5  |
| 2. Identifikasi Aset .....                           | 6  |
| 2.1. Aset Data.....                                  | 6  |
| 2.1.1. Aset Data Pengguna .....                      | 6  |
| 2.1.2. Aset Data Transaksi (Sensitif).....           | 6  |
| 2.1.3. Aset Data Konten .....                        | 7  |
| 2.2. Aset Layanan (API Endpoint) .....               | 8  |
| 2.2.1. Layanan Autentikasi.....                      | 8  |
| 2.2.2. Layanan Domain Utama.....                     | 8  |
| 2.3. Aset Infrastruktur .....                        | 9  |
| 2.4. Model Kepercayaan dan Batas Akses .....         | 9  |
| 2.4.1. Zona Kepercayaan.....                         | 10 |
| 2.4.2. Matriks Peran dan Akses .....                 | 10 |
| 3. Stack dan Dependensi Kunci.....                   | 10 |
| 3.1. Backend (FastAPI/Python).....                   | 11 |
| 3.2. Frontend (React dan Vite).....                  | 11 |
| 3.3. Arsitektur Keamanan Kriptografi.....            | 12 |

# 1. Deskripsi Sistem

## 1.1. Latar Belakang

IPB University sebagai perguruan tinggi berbasis pertanian dan agroindustri memiliki ekosistem Usaha Mikro, Kecil, dan Menengah (UMKM) yang cukup besar di lingkungan kampusnya. UMKM-UMKM ini, meliputi kantin, warung, dan usaha kuliner mahasiswa, selama ini mengandalkan transaksi langsung (offline) yang rentan terhadap masalah pencatatan, transparansi, dan efisiensi operasional.

Digitalisasi UMKM kampus melalui platform marketplace menghadirkan tantangan keamanan informasi yang nyata: data pribadi mahasiswa (nomor telepon, rekening), data transaksi keuangan, dan catatan pesanan merupakan aset yang harus dilindungi dari ancaman kebocoran, manipulasi, dan penyalahgunaan. Platform digital juga rentan terhadap serangan siber seperti credential stuffing, SQL injection, dan session hijacking yang dapat merugikan seluruh ekosistem UMKM kampus.

IPB Food Hub & UMKM dikembangkan sebagai solusi marketplace digital yang mengintegrasikan prinsip-prinsip keamanan informasi secara menyeluruh: autentikasi berbasis JWT dengan kontrol akses berbasis peran (RBAC), enkripsi data sensitif menggunakan AES-256-GCM, tanda tangan digital RSA-2048 PSS untuk non-repudiation transaksi, serta sistem audit log komprehensif mengikuti framework Authentication, Authorization, dan Accounting (AAA).

## 1.2. Gambaran Sistem

IPB Food Hub & UMKM adalah platform *web marketplace* yang mempertemukan mahasiswa IPB sebagai pembeli dengan pelaku UMKM kampus sebagai penjual. Sistem ini dikelola oleh admin yang memiliki akses penuh terhadap data pengguna, transaksi, dan dashboard keamanan. Platform ini memadukan:

- Autentikasi JWT multi-peran (mahasiswa, umkm, admin) dengan verifikasi bcrypt
- Enkripsi AES-256-GCM untuk data PII sensitif di database (nomor telepon, NIK, rekening, e-wallet)
- Tanda tangan digital RSA-2048 PSS dan SHA-256 untuk non-repudiation hasil transaksi/pesanan
- Sistem Audit Log dua lapisan: file JSON Lines (AAA) + tabel database (API request log)
- Security Dashboard real-time untuk admin menampilkan statistik autentikasi, otorisasi, dan akuntansi
- CORS policy dengan whitelist origin spesifik; rate limiting dan account lockout (rekomendasi)

## 1.3. Tujuan Sistem

- Menyediakan platform transaksi digital yang aman antara mahasiswa dan UMKM kampus IPB

- Melindungi data pribadi pengguna dengan enkripsi at-rest (AES-256-GCM) pada kolom-kolom sensitif
- Menjamin integritas dan non-repudiation setiap transaksi yang diselesaikan melalui tanda tangan digital RSA-2048
- Mencatat seluruh aktivitas autentikasi, otorisasi, dan akses API dalam audit log yang dapat diaudit
- Memberikan visibilitas keamanan real-time kepada admin melalui Security Dashboard
- Menerapkan prinsip RBAC yang ketat sehingga setiap peran hanya dapat mengakses sumber daya yang diizinkan

#### 1.4. Arsitektur Sistem

IPB Food Hub & UMKM menggunakan arsitektur client-server tiga lapisan dengan pemisahan tanggung jawab yang jelas antara presentasi, logika bisnis, dan penyimpanan data:

Tabel 1 Stack teknologi IPB Food Hub & UMKM

| Lapisan           | Teknologi                             |          | Keterangan                                                                |
|-------------------|---------------------------------------|----------|---------------------------------------------------------------------------|
| Frontend          | React 18 + Vite + CSS Modules         |          | Antarmuka web; halaman produk, keranjang, pesanan, dan dashboard keamanan |
| Backend           | FastAPI (Python 3.12) + Uvicorn       |          | REST API; logika bisnis, autentikasi, enkripsi, digital signature         |
| Database          | PostgreSQL<br>SQLAlchemy ORM          | via      | Penyimpanan data persisten; kolom sensitif dienkripsi AES-256-GCM         |
| Auth              | JWT (python-jose) + bcrypt (passlib)  |          | Token berbasis peran (3 peran); hash password bcrypt                      |
| Enkripsi          | AES-256-GCM (library cryptography)    | (library | Enkripsi at-rest kolom PII: no_telp, nik, nomor_rekening, nomor_ewallet   |
| Digital Signature | RSA-2048 PSS + SHA-256 (cryptography) |          | Tanda tangan non-repudiation pada hasil transaksi (tanda_tangan)          |

|              |                                  |                                                                           |
|--------------|----------------------------------|---------------------------------------------------------------------------|
| File Storage | Cloudinary CDN                   | Upload dan serving gambar produk, UMKM, dan bukti pembayaran              |
| Deployment   | Vercel Serverless (HTTPS)        | Hosting backend dan frontend; TLS otomatis dari Vercel                    |
| AAA Log      | Python logging (JSON Lines) + DB | Log autentikasi ke file; log API request ke tabel <code>audit_logs</code> |

---

## 1.5. Fitur Inti

### 1.5.1. Manajemen UMKM dan Menu

Pelaku UMKM dapat mendaftarkan profil usaha (nama, deskripsi, gambar, lokasi) dan mengelola daftar menu produk (nama, deskripsi, harga, stok, gambar). Admin dapat memvalidasi dan mengaktifkan/menonaktifkan akun UMKM. Gambar produk dan profil diunggah ke Cloudinary CDN dan URL-nya disimpan di database.

### 1.5.2. Alur Pemesanan dan Pembayaran

Mahasiswa memilih produk ke keranjang belanja lalu melakukan *checkout*. Setelah pesanan dibuat (status: menunggu), mahasiswa mengunggah bukti transfer pembayaran. UMKM memvalidasi pesanan dan mengubah status menjadi diproses lalu selesai. Saat pesanan berstatus selesai, sistem otomatis membuat tanda tangan digital RSA-2048 PSS atas payload transaksi dan menyimpannya di kolom `tanda_tangan` sebagai bukti non-repudiation yang tidak dapat disangkal.

### 1.5.3. Sistem Rating dan Ulasan

Mahasiswa dapat memberikan rating (1–5 bintang) dan komentar tertulis pada pesanan yang sudah selesai. Sistem mencegah duplikasi rating per pesanan. Rating agregat ditampilkan di halaman UMKM untuk membantu keputusan pembelian mahasiswa lain.

### 1.5.4. Promo dan Diskon

UMKM dapat membuat kode promo dengan persentase diskon, tanggal berlaku, dan batas penggunaan. Mahasiswa memasukkan kode promo saat checkout untuk mendapatkan potongan harga. Sistem memvalidasi kode (aktif, belum kadaluarsa, belum melewati batas).

### 1.5.5. Dashboard Keamanan (Security Dashboard)

Khusus admin, tersedia *Security Dashboard* real-time yang menampilkan statistik AAA:

- *Authentication*: total percobaan login, login berhasil/gagal, success rate, login hari ini
- *Authorization*: total request hari ini, access denied (403), pengguna aktif hari ini
- *Accounting*: total log, log hari ini, log minggu ini, distribusi peran pengguna

- Tabel audit log dengan filter: method, status code, user\_id, endpoint, pagination

## 2. Identifikasi Aset

Identifikasi aset dilakukan berdasarkan analisis model SQLAlchemy, modul router backend, layanan frontend, dan konteks penggunaan sistem marketplace UMKM kampus. Aset dikategorikan menjadi: Aset Data, Aset Layanan, dan Aset Infrastruktur.

### 2.1. Aset Data

#### 2.1.1. Aset Data Pengguna

Sistem memiliki tiga entitas pengguna dengan atribut sensitif yang berbeda:

Tabel 2 Aset data entitas pengguna

| Entitas                | Tabel DB                  | Atribut Sensitif                                                                                                                     | Nilai  |
|------------------------|---------------------------|--------------------------------------------------------------------------------------------------------------------------------------|--------|
| Admin                  | users<br>(role=admin)     | password (bcrypt),<br>email, nama, status,<br>hak_akses                                                                              | Kritis |
| UMKM<br>(Penjual)      | users<br>(role=umkm)      | password (bcrypt),<br>email, no_telp (AES-<br>GCM), nik (AES-<br>GCM),<br>nomor_rekening<br>(AES-GCM),<br>nomor_ewallet<br>(AES-GCM) | Kritis |
| Mahasiswa<br>(Pembeli) | users<br>(role=mahasiswa) | password (bcrypt),<br>email, no_telp (AES-<br>GCM), nim,<br>fakultas, departemen,<br>angkatan                                        | Tinggi |

Kolom no\_telp, nik, nomor\_rekening, dan nomor\_ewallet dienkripsi menggunakan AES-256-GCM melalui TypeDecorator SQLAlchemy (EncryptedString) sehingga nilai yang tersimpan di database selalu berupa ciphertext, bukan plaintext.

#### 2.1.2. Aset Data Transaksi (Sensitif)

Berikut ini adalah kategori aset paling sensitif data transaksi keuangan.

Tabel 3 Aset data transaksi

| Tabel              | Deskripsi                                                                                                                      | Nilai  |
|--------------------|--------------------------------------------------------------------------------------------------------------------------------|--------|
| pesanan            | Data transaksi lengkap: mahasiswa_id, umkm_id, total, status, bukti_pembayaran (URL), tanda_tangan (RSA-2048 signature base64) | Kritis |
| item_pesanan       | Detail item per pesanan: menu_id, jumlah, harga_satuan, subtotal                                                               | Tinggi |
| audit_logs         | Log setiap HTTP request: user_id, method, endpoint, status_code, ip_address, user_agent, duration_ms                           | Tinggi |
| aaa_accounting.log | Log autentikasi (JSON Lines): LOGIN_SUCCESS, LOGIN_FAILED, USER_REGISTER, ACCESS_GRANTED, ACCESS_DENIED, PROFILE_UPDATE        | Sedang |

Kolom tanda\_tangan pada tabel pesanan menyimpan signature RSA-2048 PSS yang dihitung saat pesanan berstatus selesai. Signature ini membuktikan integritas data transaksi dan memberikan non-repudiation, baik penjual maupun pembeli tidak dapat menyangkal terjadinya transaksi.

### 2.1.3. Aset Data Konten

Tabel 4: Aset data konten

| Tabel  | Deskripsi                                                                         | Nilai  |
|--------|-----------------------------------------------------------------------------------|--------|
| menu   | Daftar produk UMKM: nama, deskripsi, harga, stok, gambar (Cloudinary URL), status | Sedang |
| umkm   | Profil UMKM: nama_usaha, deskripsi, lokasi, gambar, jam_operasional               | Sedang |
| rating | Ulasan mahasiswa: nilai (1–5), komentar, pesanan_id, mahasiswa_id, umkm_id        | Sedang |

|       |                                                                                             |
|-------|---------------------------------------------------------------------------------------------|
| promo | Kode promo: kode, diskon (%), Rendah<br>tanggal_mulai, tanggal_selesai,<br>batas_penggunaan |
|-------|---------------------------------------------------------------------------------------------|

## 2.2. Aset Layanan (API Endpoint)

### 2.2.1. Layanan Autentikasi

Tabel 5: Layanan autentikasi

|                    |      |                                                               |
|--------------------|------|---------------------------------------------------------------|
| /api/auth/login    | POST | Login dengan email + password; mengembalikan JWT Bearer token |
| /api/auth/register | POST | Registrasi akun baru (mahasiswa/umkm); validasi email unik    |
| /api/auth/me       | GET  | Ambil profil pengguna aktif berdasarkan JWT yang dikirim      |
| /api/auth/me       | PUT  | Update profil pengguna; dicatat ke AAA log (PROFILE_UPDATE)   |

### 2.2.2. Layanan Domain Utama

Tabel 6: Layanan domain utama

| Modul           | Deskripsi Layanan                                                                                     | Peran Akses            |
|-----------------|-------------------------------------------------------------------------------------------------------|------------------------|
| UMKM Management | CRUD profil UMKM; kelola informasi toko, jam, lokasi                                                  | Admin, UMKM            |
| Menu Management | CRUD menu produk; upload gambar ke Cloudinary                                                         | UMKM                   |
| Pesanan         | Buat pesanan, upload bukti bayar, validasi pesanan, update status; trigger RSA signature saat selesai | Mahasiswa, UMKM        |
| Rating & Ulasan | Buat rating per pesanan selesai; lihat daftar rating per UMKM                                         | Mahasiswa, UMKM, Admin |



|                    |                                                                                                                           |                 |
|--------------------|---------------------------------------------------------------------------------------------------------------------------|-----------------|
| Promo              | Buat/edit/hapus kode promo; validasi kode saat checkout                                                                   | UMKM, Mahasiswa |
| Admin Dashboard    | Kelola akun pengguna; lihat semua transaksi; moderasi                                                                     | Admin           |
| Security Dashboard | GET /api/security/stats, statistik AAA real-time;<br>GET /api/security/audit-logs, tabel log dengan filter dan pagination | Admin           |

### 2.3. Aset Infrastruktur

Tabel 7: Aset infrastruktur

| Komponen             | Deskripsi                                                              | Nilai  |
|----------------------|------------------------------------------------------------------------|--------|
| FastAPI Backend      | Python runtime menjalankan REST API; semua logika keamanan ada di sini | Kritis |
| PostgreSQL (Neon DB) | Penyimpanan data persisten; kolom sensitif terenkripsi AES-256-GCM     | Kritis |
| JWT SECRET_KEY       | Secret key HS256 untuk signing/verifikasi token seluruh peran          | Kritis |
| ENCRYPTION_KEY       | 32-byte AES key (base64) untuk enkripsi/dekripsi kolom PII             | Kritis |
| RSA Private Key      | Private key RSA-2048 PSS untuk signing transaksi selesai               | Kritis |
| Cloudinary API Key   | Kredensial upload/serving gambar produk dan bukti pembayaran           | Tinggi |
| Vercel Serverless    | Hosting HTTPS; TLS otomatis; environment variables tersimpan di Vercel | Tinggi |
| React Frontend       | SPA; mengonsumsi API backend; mengirim JWT di Authorization header     | Sedang |

### 2.4. Model Kepercayaan dan Batas Akses

### 2.4.1. Zona Kepercayaan

Sistem mendefinisikan tiga zona kepercayaan:

- 1. Zona Publik:** Internet, pengguna tidak terautentikasi; hanya dapat mengakses endpoint `/api/auth/login` dan `/api/auth/register`.
- 2. Zona Terautentikasi:** Pengguna dengan JWT Bearer token valid; akses dikontrol oleh `require_role(allowed_roles)` sesuai peran (mahasiswa/umkm/admin).
- 3. Zona Internal:** Komunikasi FastAPI dengan PostgreSQL; hanya dapat diakses dari host server (Vercel Serverless environment).

### 2.4.2. Matriks Peran dan Akses

Tabel 8: Matriks akses per peran

| Fitur / Endpoint                 | Admin    | UMKM              | Mahasiswa |
|----------------------------------|----------|-------------------|-----------|
| Login & Register                 | ✓        | ✓                 | ✓         |
| Kelola akun pengguna             | ✓ (full) | ✗                 | ✗         |
| CRUD profil UMKM                 | ✓        | ✓ (milik sendiri) | ✗         |
| CRUD menu produk                 | ✓        | ✓ (milik sendiri) | ✗         |
| Buat pesanan                     | ✗        | ✗                 | ✓         |
| Upload bukti pembayaran          | ✗        | ✗                 | ✓         |
| Validasi & update status pesanan | ✓        | ✓ (pesanan masuk) | ✗         |
| Buat rating & ulasan             | ✗        | ✗                 | ✓         |
| Kelola promo                     | ✓        | ✓ (milik sendiri) | ✗         |
| Security Dashboard & Audit Log   | ✓        | ✗                 | ✗         |
| Lihat semua transaksi            | ✓        | ✗                 | ✗         |

## 3. Stack dan Dependensi Kunci

### 3.1. Backend (FastAPI/Python)

Tabel 9: Dependensi utama backend

| Paket                     | Versi   | Fungsi Keamanan                                              |
|---------------------------|---------|--------------------------------------------------------------|
| fastapi                   | 0.111.0 | Framework REST API; dependency injection untuk autentikasi   |
| python-jose[cryptography] | 3.3.0   | Generasi dan verifikasi JWT (HS256); klaim payload           |
| passlib[bcrypt]           | 1.7.4   | Hashing password bcrypt; work factor adaptif                 |
| bcrypt                    | 4.1.3   | Driver bcrypt untuk passlib                                  |
| cryptography              | 42.0.7  | AES-256-GCM (AESGCM), RSA-2048 PSS, SHA-256, serialisasi PEM |
| sqlalchemy                | 2.0.30  | ORM; TypeDecorator EncryptedString untuk enkripsi transparan |
| pydantic                  | 2.7.4   | Validasi dan sanitasi input request body                     |
| uvicorn                   | 0.30.1  | ASGI server; middleware HTTP untuk audit logging             |
| starlette                 | 0.37.2  | CORSMiddleware dengan whitelist origin; StaticFiles          |
| cloudinary                | 1.41.0  | Upload gambar terkelola; URL aman via CDN                    |
| psycopg2-binary           | 2.9.9   | Driver PostgreSQL                                            |

### 3.2. Frontend (React dan Vite)

Tabel 10: Dependensi utama frontend

| Paket            | Versi | Fungsi                                                         |
|------------------|-------|----------------------------------------------------------------|
| react            | 18.x  | Library UI komponen; state management lokal                    |
| vite             | 5.x   | Build tool; env variable VITE_API_URL untuk base URL API       |
| axios / fetch    | —     | HTTP client; mengirim JWT Bearer token di Authorization header |
| react-router-dom | 6.x   | Client-side routing; proteksi halaman berdasarkan role         |

### 3.3. Arsitektur Keamanan Kriptografi

Keputusan desain penting dalam sistem ini adalah pemisahan dua lapisan kriptografi yang berbeda tujuan:

- AES-256-GCM (simetris), digunakan untuk enkripsi at-rest kolom PII di database. Setiap enkripsi menggunakan IV (nonce) 12-byte yang di-generate secara acak, sehingga ciphertext yang sama menghasilkan output berbeda setiap kali. GCM mode memberikan authenticated encryption (AEAD) yang mendeteksi tampering.
- RSA-2048 PSS (asimetris), digunakan untuk tanda tangan digital transaksi selesai. Private key digunakan untuk signing; public key dapat dibagikan untuk verifikasi. Pendekatan asimetris ini memungkinkan siapa pun memverifikasi keaslian transaksi tanpa mengetahui private key.
- Bcrypt, digunakan untuk hashing password sebelum disimpan ke database. bcrypt memiliki work factor adaptif yang memperlambat brute force attack.